ZAP by Checkmarx Scanning Report

Site: http://localhost:5173

Generated on Tue, 9 Dec 2025 16:51:02

ZAP Version: 2.16.1

ZAP by Checkmarx

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	2
Low	1
Informational	1

Summary of Sequences

For each step: result (Pass/Fail) - risk (of highest alert(s) for the step, if any).

Alerts

Name	Risk Level	Number of Instances
Content Security Policy (CSP) Header Not Set	Medium	4
Missing Anti-clickjacking Header	Medium	4
X-Content-Type-Options Header Missing	Low	6
Modern Web Application	Informational	4

Alert Detail

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://localhost:5173/
Method	GET

Parameter	
Attack	
Evidence	
Other Info	
URL	http://localhost:5173/robots.txt
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://localhost:5173/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
URL	http://localhost:5173/vite.svg
Method	GET
Parameter	
Attack	
Evidence	
Other Info	
Instances	4
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/ https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	**Missing Anti-clickjacking Header**
Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	http://localhost:5173/
Method	GET
Parameter	x-frame-options

Attack	
Evidence	
Other Info	
URL	http://localhost:5173/robots.txt
Method	GET
Parameter	x-frame-options
Attack	
Evidence	
Other Info	
URL	http://localhost:5173/sitemap.xml
Method	GET
Parameter	x-frame-options
Attack	
Evidence	
Other Info	
URL	http://localhost:5173/vite.svg
Method	GET
Parameter	x-frame-options
Attack	
Evidence	
Other Info	
Instances	4
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Low	**X-Content-Type-Options Header Missing**
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://localhost:5173/
Method	GET
Parameter	x-content-type-options
Attack	

Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:5173/@vite/client
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:5173/robots.txt
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:5173/sitemap.xml
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:5173/src/main.jsx
Method	GET
Parameter	x-content-type-options
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://localhost:5173/vite.svg
Method	GET
Parameter	x-content-type-options
Attack	

Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	6
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application/web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational **Modern Web Application**

Description	The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one.
URL	http://localhost:5173/
Method	GET
Parameter	
Attack	
Evidence	<script type="module">import { injectIntoGlobalHook } from "/@react-refresh"; injectIntoGlobalHook(window); window.$RefreshReg$ = () => {}; window.$RefreshSig$ = () => (type) => type;</script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:5173/robots.txt
Method	GET
Parameter	
Attack	
Evidence	<script type="module">import { injectIntoGlobalHook } from "/@react-refresh"; injectIntoGlobalHook(window); window.$RefreshReg$ = () => {}; window.$RefreshSig$ = () => (type) => type;</script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
URL	http://localhost:5173/sitemap.xml
Method	GET
Parameter	
Attack	
Evidence	<script type="module">import { injectIntoGlobalHook } from "/@react-refresh"; injectIntoGlobalHook(window); window.$RefreshReg$ = () => {}; window.$RefreshSig$ = () => (type) => type;</script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.

URL	http://localhost:5173/vite.svg
Method	GET
Parameter	
Attack	
Evidence	<script type="module">import { injectIntoGlobalHook } from "/@react-refresh"; injectIntoGlobalHook(window); window.$RefreshReg$ = () => {}; window.$RefreshSig$ = () => (type) => type;</script>
Other Info	No links have been found while there are scripts, which is an indication that this is a modern web application.
Instances	4
Solution	This is an informational alert and so no changes are required.
Reference	
CWE Id	
WASC Id	
Plugin Id	10109

Sequence Details

With the associated active scan results.